

Viju - Consolidated Backend Work Register

Merged pending backend items from the Web Portal specification (Account Officer, Administrator, Regional Admin, Loading Officer) and the Customer Mobile App specification.

36 items total - 24 web, 12 mobile | Timeline: 18 at 3 days, 18 at 5 days | All items Status = Pending | Base URL: https://dev-api-viju.optisoft.com.ng/api/v1

Endpoint Provided: Yes = the web portal already has endpoints provided by the backend; No = not yet provided for the mobile app. Timeline: 3 days = additive fields or behaviour on a working route; 5 days = new endpoint, new state model, or new infrastructure.

Shared scope: web A0-13 and mobile BE-07 are the same push delivery work. Web A0-10/CC-03 and mobile BE-08 are the same realtime channel. Web L0-05 produces the waybill record mobile BE-05 exposes to the customer. Deliver each once.

Issue	Platform	Status	Time Line	Endpoint Provided	Endpoint Exists?	Existing Frontend / Mobile Endpoint(s)	Expectation / Required Backend Changes	New Endpoint (if Required)	Request Body	Query / Filters	Sample Response
A0-05 Dashboard: sort table by any column (US-09.3)	Web	Pending	5 days	Yes	YES modify	GET /officers/customers GET /admin/customers GET /admin/officers GET /admin/audit/tickets	FE sends only page, pageSize, search (+region on customers/officers). components/common/tables.tsx declares a 'sortable' flag that is never read, so no table can be sorted. Add optional sortBy + sortOrder to all four list endpoints. Default (params absent) must keep today's ordering so nothing regresses. Reject an unknown sortBy with 400 rather than silently ignoring it. Response envelope unchanged - only row order changes.	n/a - extend existing routes	n/a (GET)	sortOrder: asc desc (default desc) sortBy per route: /officers/customers: name accountNumber walletBalance lastPurchaseDate openTickets lastContactDate /admin/customers: name erpId region outstandingBalance supportTickets /admin/officers: name email region customers createdAt lastLoginAt /admin/audit/tickets: ticketId subject customerName region status createdAt	Unchanged envelope, reordered rows: { "data": [...], "meta": { "total": 150, "page": 1, "pageSize": 20, "totalPages": 8, "hasNextPage": true, "hasPreviousPage": false } }
A0-08 Last updated timestamp on every ERP-backed screen (US-10.7, PRD s7)	Web	Pending	3 days	Yes	YES modify	GET /officers/customers/{id}/overview (already returns lastUpdated) GET /officers/customers/{id}/orders GET /officers/customers/{id}/invoices GET /officers/customers/{id}/stock GET /officers/customers/{id}/waybills	Only the overview response carries lastUpdated, so only the Overview tab can render the PRD-mandated 'Last updated' stamp. PRD s7 requires it on every screen showing ERP data. Add a top-level lastUpdated (ISO-8601 UTC) to the other four responses, reflecting the last ERP sync for that dataset - not the request time. Purely additive.	n/a - extend existing routes	n/a (GET)	Unchanged (orders and waybills keep page, pageSize)	Orders / waybills: { "lastUpdated": "2026-08-19T09:15:00Z", "data": [...], "meta": { ... } } Invoices: { "lastUpdated": "...", "walletBalance": 1240000, "invoices": [...], "paymentHistory": [...] } Stock: { "lastUpdated": "...", "catalogue": [...], "awaitingLoading": [...] }
A0-10 / CC-03 Real-time delivery for chat, tickets and the bell (US-11.2)	Web	Pending	5 days	Yes	NO new	GET /chat/{otherUserId} POST /chat/{receiverId} GET /tickets/officer GET /notifications/me	There is no socket layer in the codebase and React Query staleTime is 5 minutes, so an officer only sees a new message, ticket or notification after navigating or waiting out the cache. Provide a server-push channel. FE will subscribe and invalidate the matching query keys - it keeps WAITING through the existing REST routes, so this channel is server-to-client only. Shares scope with mobile BE-08.	WSS /realtime (or SSE: GET /realtime/stream)	n/a - no body; handshake carries the bearer token	token=<access_token> (required) channels=chat,tickets,notifications (optional, defaults to all)	Event frames: { "event": "chat.message", "data": { "id": "msg_1", "senderId": "cus_9", "receiverId": "stf_2", "content": "Hello", "createdAt": "..." } } { "event": "ticket.updated", "data": { "id": "tkt_1", "ticketId": "TCK-1042", "status": "IN_PROGRESS" } } { "event": "notification.created", "data": { "id": "ntf_1", "content": "New message from Ade Foods Ltd", "type": "CHAT_MESSAGE", "isRead": false } }
A0-12 In-app bell notification on new message or ticket (US-11.8)	Web	Pending	3 days	Yes	YES (read) emission missing	GET /notifications/me?page&pageSize correctly. The gap is that no notification rows are ever created, because the backend does not emit them. Create a row addressed to the assigned officer whenever a customer sends a chat message or raises a ticket (PRD s5). No contract change - only that records exist. Keep `type` values stable and enumerated.	The read and mark-as-read routes work and the bell renders {unread, data, meta} correctly. The gap is that no notification rows are ever created, because the backend does not emit them. Create a row addressed to the assigned officer whenever a customer sends a chat message or raises a ticket (PRD s5). No contract change - only that records exist. Keep `type` values stable and enumerated.	n/a - server-side side effect	n/a	Existing: page, pageSize	{ "unread": 3, "data": [{ "id": "ntf_01", "customerId": "cus_9", "staffId": "stf_2", "content": "New message from Ade Foods Ltd", "isRead": false, "type": "CHAT_MESSAGE", "createdAt": "..." }, { "id": "ntf_1", "content": "New message from Ade Foods Ltd", "type": "CHAT_MESSAGE", "isRead": false }], "meta": { "total": 12, "page": 1, "pageSize": 20, "totalPages": 1 } }
A0-13 Customer receives push when officer replies or changes status (US-11.7)	Web	Pending	5 days	Yes	NO new (+ mobile)	None - the web app does not consume push. It only triggers the events via: POST /chat/{receiverId} POST /tickets/{id}/replies PATCH /tickets/{id}/status	The web app already performs the three actions that must notify a customer. The backend must fan those out to FCM/APNs. No new web client code is required. SAME WORK AS MOBILE BE-07 - deliver once and both items close; the device-token registration route belongs to the mobile side.	See mobile BE-07: POST /customers/me/devices DELETE /customers/me/devices/{token} plus internal push dispatch on chat send, ticket reply and ticket status change	n/a for web (web only triggers the events)	n/a. Auth: customer bearer token on the mobile registration route.	Push payload delivered to the device: { "notification": { "title": "Ifeanyi Okon", "body": "Your ticket has a new reply!", "data": { "type": "TICKET_REPLY", "entityId": "tkt_1", "notificationId": "ntf_1" } } }
AD-04 Admin opens any customer's full detail with the officer tab set (US-12.3)	Web	Pending	5 days	Yes	NO for ADMIN (officer-scoped versions exist)	GET /officers/customers/{id}/overview GET /officers/customers/{id}/orders GET /officers/customers/{id}/invoices GET /officers/customers/{id}/stock GET /officers/customers/{id}/waybills (all officer-scoped; an ADMIN has no route to this data)	US-12.3 requires an admin to open ANY customer and see the same tabs as the officer. Every detail route is officer-scoped and filtered to the caller's own assignments, so the admin UI can only show a summary modal today. Two acceptable fixes: (a) PREFERRED - widen the five existing routes to accept ADMIN and skip the assigned-officer check for it; or (b) mirror them under /admin/customers/{id}/... Either way the response bodies must be byte-identical to the officer versions so the FE reuses OverviewSection, OrdersSection, InvoicesSection, StockSection and WaybillsSection unchanged.	Option (a): no new paths - widen the role check on the five existing routes Option (b): GET /admin/customers/{id}/overview GET /admin/customers/{id}/orders GET /admin/customers/{id}/invoices GET /admin/customers/{id}/stock GET /admin/customers/{id}/waybills	n/a (GET)	orders and waybills: page, pageSize (identical to the officer routes)	Identical to /officers/customers/{id}/ . Overview example: { "id": "cus_9", "name": "Ade Foods Ltd", "phone": "+2348012345678", "region": "LAGOS", "walletBalance": 2340000, "assignedOfficers": [{ "id": "stf_2", "name": "Ifeanyi Okon" }], "lastUpdated": "..." }
AD-08 New officer notified that a customer was assigned (US-13.4)	Web	Pending	3 days	Yes	YES add side effect	PATCH /admin/customers/{id}/reassign PATCH /admin/officers/{id}/reassign-customers	Both calls already succeed and the FE invalidates the customer, officer and dashboard caches. The missing half is US-13.4: the RECEIVING officer must get an in-app notification. Emit one notification per reassigned customer for the single-customer route, and one summary notification for the bulk route. No request or response change - the FE only needs the row to exist so it appears in the bell.	n/a - server-side side effect on existing routes	Unchanged: { "newOfficerId": "stf_7" }	n/a	Responses unchanged: { "message": "Operation completed successfully" } { "reassigned": 15, "fromOfficerId": "stf_2", "toOfficerId": "stf_7" } Side effect - notification row for the new officer: { "staffId": "stf_7", "content": "Ade Foods Ltd has been assigned to you", "type": "ASSIGNMENT", "isRead": false }
AD-09 Chat history and tickets carry over on reassignment (US-13.5)	Web	Pending	3 days	Yes	YES behaviour guarantee	PATCH /admin/customers/{id}/reassign PATCH /admin/officers/{id}/reassign-customers Verified through: GET /chat/{customerId} GET /tickets/officer	US-13.5 states no data is lost on reassignment. This is not verifiable from the frontend, so it needs an explicit backend guarantee and a QA check. After a reassignment the NEW officer must see the complete pre-existing chat thread and every ticket for that customer, and the OLD officer must lose access. Confirm chat/ticket ownership derives from the current assignment (or is re-pointed) rather than copied or left orphaned on the previous officer.	n/a	n/a	n/a	Responses unchanged. Acceptance check: message and ticket counts for the customer are identical before and after reassignment, and GET /chat/{customerId} as the OLD officer returns 403.
AD-12 Audit: all chat threads visible, not just tickets (US-14.2)	Web	Pending	5 days	Yes	NO new	GET /admin/audit/tickets GET /admin/audit/tickets/export.csv	US-14.2 requires the admin to read chat conversations AND ticket threads. Only the ticket audit exists - chat auditing is entirely absent. Provide a chat audit that mirrors the ticket audit's filters and response envelope exactly, so the existing audits page can host it as a second tab reusing the same table, filter and pagination code. Must be strictly read-only (US-14.3).	GET /admin/audit/chats GET /admin/audit/chats/export.csv	n/a (GET)	Identical to the ticket audit: page, pageSize, region, customerName, officerName, keyword, startDate, endDate keyword must match message body text. region: LAGOS EASTERN SOUTH_SOUTH WESTERN NORTH	{ "data": [{ "id": "cht_1", "customer": { "id": "cus_9", "name": "Ade Foods Ltd", "region": "LAGOS", "officer": { "id": "stf_2", "name": "Ifeanyi Okon", "messageCount": 24, "lastMessageAt": "...", "messages": [{ "id": "msg_1", "senderType": "CUSTOMER", "content": "When is my waybill ready?", "createdAt": "..." }] }, "meta": { "total": 57, "page": 1, "pageSize": 20, "totalPages": 3 } }] }
AD-15 Officer list: open tickets and last login columns (US-15.1)	Web	Pending	3 days	Yes	YES modify	GET /admin/officers?page&pageSize&search®ion	US-15.1 requires the officer list to show open tickets and last login. The response carries neither, so app/admin/officers/page.tsx hardcodes the ticket count to 0 and substitutes createdAt for last login - both misleading. Add lastLoginAt (nullable ISO-8601, null until first login) and _count.supportTickets (open tickets across that officer's customers). Purely additive.	n/a - extend existing route	n/a (GET)	Existing: page, pageSize, search, region	{ "data": [{ "id": "stf_2", "name": "Ifeanyi Okon", "email": "i.okon@viju.com", "phone": "+2348012345678", "region": "LAGOS", "isActive": true, "createdAt": "...", "lastLoginAt": "2026-08-19T07:41:00Z", "_count": { "customers": 14, "supportTickets": 3 } }, { "id": "stf_3", "name": "Ifeanyi Okon", "email": "i.okon@viju.com", "phone": "+2348012345678", "region": "LAGOS", "isActive": true, "createdAt": "...", "lastLoginAt": "2026-08-19T07:41:00Z", "_count": { "customers": 14, "supportTickets": 3 } }], "meta": { "total": 32, "page": 1, "pageSize": 20 } }
AD-17 New officer receives an email with login details (US-15.3)	Web	Pending	3 days	Yes	YES add side effect	POST /admin/officers	The FE posts the new officer and then shows a success modal telling the admin the officer 'will receive an email with their login credentials'. No email is actually sent, so that message is currently false. Send the credentials email as a side effect of a successful create. Optionally return emailSent so the FE can soften the wording when delivery fails.	n/a - server-side side effect on the existing route	Unchanged: { "name": "Ifeanyi Okon", "email": "i.okon@viju.com", "phone": "+2348012345678", "region": "LAGOS", "password": "TempPass123" }	n/a. Auth: ADMIN only.	201 (emailSent is the only addition): { "id": "stf_9", "name": "Ifeanyi Okon", "email": "i.okon@viju.com", "region": "LAGOS", "isActive": true, "emailSent": true }
AD-18 Deactivate an officer, blocked until customers are reassigned (US-15.4)	Web	Pending	5 days	Yes	NO new	None. components/PreviewAccountOfficerModal.tsx fakes success with a setTimeout and calls no API at all.	The confirm modal is fully built but has nothing to call, so deactivation does not work. Provide a deactivate route (the same route reactivates with isActive true). It MUST refuse while the officer still holds customers, and the refusal must carry a machine-readable code plus the count, so the FE can tell the admin exactly how many customers to move first. The FE then calls the existing reassign-customers route and retries.	PATCH /admin/officers/{id}	{ "isActive": false } Same route reactivates: { "isActive": true }	n/a. Auth: ADMIN only.	200 success: { "id": "stf_2", "name": "Ifeanyi Okon", "isActive": false, "updatedAt": "..." } 409 blocked (FE renders `message` verbatim): { "message": "Reassign this officer's 14 customers before deactivating.", "code": "OFFICER_HAS_CUSTOMERS", "assignedCustomers": 14, "statusCode": 409 }
AD-19 Deactivated officer cannot log in; history stays visible (US-15.5)	Web	Pending	3 days	Yes	YES modify	POST /auth/staff/login POST /auth/staff/web-login POST /auth/refresh	Reject authentication for staff with isActive false on BOTH login routes, and refuse to mint or refresh tokens for them so any live session dies at its next refresh. No FE change needed: the axios client already surfaces the 'no cross-region verbatim, and a 401 on refresh already forces a logout and redirect. Past chat and ticket history must remain readable by admins in the audit views.	n/a - extend existing routes	Unchanged	n/a	403 on login, and on refresh for a deactivated account: { "message": "This account has been deactivated. Contact an administrator.", "statusCode": 403 }
RA-02 Regional dashboard: summary cards and pending loading requests	Web	Pending	3 days	Yes	YES contract unverified	GET /regional/dashboard?region=LAGOS	The FE types this response but has NEVER exercised it - app/dashboard/page.tsx returns mock rows for REGIONAL_ADMIN unconditionally, leaving the real branch as unreachable dead code. Backend to confirm the live response matches the typed shape exactly before the FE deletes the mock. pendingLoadingRequests cannot be populated until loading data exists (RA-06), and `region` should stop being trusted from the query string (RA-03).	n/a - existing route, confirm contract	n/a (GET)	region is currently sent by the FE. It should become server-derived from the token and the query param ignored or rejected.	{ "summary": { "totalDistributors": 256, "openTickets": 4, "pendingWaybills": 11, "activeOfficers": 8 }, "pendingLoadingRequests": [{ "id": "lr_1", "reference": "ORD-00294", "distributorName": "Bello & Sons LTD", "loadingDate": "...", "truckPlateNumber": "LAG-234-XY", "driverName": "John Dare", "quantityCartons": 320, "status": "PENDING", "submittedAt": "..." }] }
RA-03 Data scoped to the user's own region	Web	Pending	5 days	Yes	YES modify	POST /auth/staff/login POST /auth/staff/web-login GET /users/me	The User type declares region as optional but it is not reliably returned, so useDashboard hardcodes 'LAGOS' for every regional admin and the sidebar badge is static text. That is a cross-region data-leak risk against the 'no cross-region leakage' principle. Return region on the login user object and from /users/me for REGIONAL_ADMIN, OFFICER and LOADING_OFFICER (null for org-wide ADMIN). CRITICAL: every region-scoped endpoint must filter by the TOKEN's region server-side, never by a client-supplied query param.	n/a - extend existing routes	Unchanged	n/a	{ "access_token": "eyJ...", "refresh_token": "eyJ...", "expires_in": 3600, "user": { "id": "stf_5", "name": "Othello Eze", "role": "REGIONAL_ADMIN", "region": "EASTERN" } } region: LAGOS EASTERN SOUTH_SOUTH WESTERN NORTH null

	Platform	Status	Time Line	Endpoint Provided	Endpoint Exists?	Existing Frontend / Mobile Endpoint(s)	Expectation / Required Backend Changes	New Endpoint (if Required)	Request Body	Query / Filters	Sample Response
RA-05 Officers list for the region	Web	Pending	3 days	Yes	YES modify	GET /admin/officers?page&pageSize&search®ion	The regional officers page previously rendered a hardcoded 25-row array; the FE fix has shipped and it now calls this route live, sending region from user.region. Two backend gaps remain: (1) confirm /admin/officers actually honours the region query param - /admin/customers does, but this route was never verified; (2) the route is admin-scoped, so allow REGIONAL_ADMIN and force the filter to the token's region, ignoring any client-supplied value. Response shape unchanged.	n/a - extend existing route	n/a (GET)	page, pageSize, search, region region: LAGOS EASTERN SOUTH_SOUTH WESTERN NORTH	Existing OfficersListResponse envelope, filtered to one region: { "data": [{"id": "stf_2", "name": "Ifeanyi Okon", "region": "EASTERN", "isActive": true, "count": {"customers": 14}}], "meta": {"total": 6, "page": 1, "pageSize": 10}}
RA-06 Loading requests list and assign to a loading officer	Web	Pending	5 days	Yes	NO new	None. app/requests/loading/page.tsx and components/AssignLoadingOfficerModal.tsx are fully mocked - the modal even lists three hardcoded officers.	A regional admin lists pending loading requests for their region and assigns each to a loading officer. The FE already renders the columns waybill, distributor, order, truck, driver, submitted, officer and status, and has filter tabs All / Pending / Assigned / Loading In Progress / Completed - so the list route needs a status filter matching those tabs. The assign modal also needs a real source of loading officers; reusing /admin/officers with a role filter avoids a new route.	GET /regional/loading-requests PATCH /regional/loading-requests/{id}/assign plus officer picker: GET /admin/officers?role=LOADING_OFFICER	Assign: { "loadingOfficerId": "stf_11" }	List: page, pageSize, search, status status: PENDING ASSIGNED IN_PROGRESS COMPLETED Region derived from the token, not the query.	{ "data": [{"id": "lr_1", "waybill": "WB-19045", "reference": "ORD-00294", "distributorName": "Bello & Sons LTD", "truckPlateNumber": "LAG-234-XY", "driverName": "John Dare", "quantityCartons": 320, "status": "PENDING", "assignedOfficer": null}], "meta": {"total": 11, "page": 1, "pageSize": 10}} Assign 200: { "id": "lr_1", "status": "ASSIGNED", "assignedOfficer": { "id": "stf_11", "name": "Ifeanyi Okon" } }
LO-02 My Loading Queue	Web	Pending	5 days	Yes	NO new	None. app/loading/queue/page.tsx and every file under components/loadingOfficer/ are 100% mock with zero API calls.	The signed-in loading officer must see only their own assignments. The FE list already renders id, orderId, distributorName, region, submittedAt and a status of assigned in-progress completed, and groups them by those three states. Scope by the officer on the token - never accept an officerId from the client.	GET /loading/queue	n/a (GET)	page, pageSize, status status: ASSIGNED IN_PROGRESS COMPLETED Officer derived from the token.	{ "data": [{"id": "lr_1", "orderId": "ORD-00999", "distributorName": "Ibonodu Mega Distributor", "region": "LAGOS", "submittedAt": "...", "status": "ASSIGNED"}], "meta": {"total": 8, "page": 1, "pageSize": 20, "totalPages": 1}}
LO-03 Assignment detail view	Web	Pending	3 days	Yes	NO new	None - the detail panel is driven by a hardcoded mockDetailsMap keyed by row id.	Selecting a queue item opens its detail panel. The FE renders orderId, distributorName, region, submittedAt, truck, driver, loadingDate, quantity and currentStatus. Must return 403 if the assignment does not belong to the caller, so one loading officer cannot read another's work.	GET /loading/queue/{id}	n/a (GET)	n/a. Caller must own the assignment.	{ "id": "lr_1", "orderId": "ORD-00999", "distributorName": "Ibonodu Mega Distributor", "region": "LAGOS", "truckPlateNumber": "RJ-290", "driverName": "John Dare", "loadingDate": "...", "quantityCartons": 320, "status": "ASSIGNED" }
LO-04 Update loading status / mark complete	Web	Pending	3 days	Yes	NO new	None - no UI action is wired and no endpoint exists.	The officer advances a load through ASSIGNED -> IN_PROGRESS -> COMPLETED. Reject illegal transitions (for example COMPLETED back to ASSIGNED) with 409 rather than silently accepting them. The change should also surface on the regional admin dashboard, so emit the same waybill update that feeds RA-02's pendingLoadingRequests.	PATCH /loading/queue/{id}/status	{ "status": "IN_PROGRESS" } status: IN_PROGRESS COMPLETED	n/a. Caller must own the assignment.	200: { "id": "lr_1", "status": "IN_PROGRESS", "updatedAt": "..."} 409 illegal transition: { "message": "A completed load cannot be reopened.", "code": "INVALID_STATUS_TRANSITION", "statusCode": 409 }
LO-05 Waybill capture: truck, driver, quantity	Web	Pending	5 days	Yes	PARTLY read-only route exists	GET /officers/customers/{id}/waybills (read-only, customer-scoped)	Only a read view of waybills exists. The loading officer must be able to RECORD the completed load - truck, driver, quantity and an optional proof-of-loading image. The image can reuse the existing POST /uploads route, so only the waybill write route is new. The record created here is what the existing read route should subsequently return, and what mobile BE-05 exposes to the customer.	POST /loading/queue/{id}/waybill	{ "truckPlateNumber": "LAG-234-XY", "driverName": "John Dare", "quantityCartons": 320, "attachmentUrl": "https://res.cloudinary.com/.../proof.jpg" } attachmentUrl optional; obtained from the existing POST /uploads	n/a. Caller must own the assignment.	201: { "id": "wb_1", "waybillNumber": "WB-19045", "loadingRequestId": "lr_1", "truckPlateNumber": "LAG-234-XY", "driverName": "John Dare", "quantityCartons": 320, "status": "COMPLETED", "createdAt": "..."} createdAt optional; obtained from the existing POST /uploads
CC-01 Role-based access control (CRITICAL)	Web	Pending	5 days	Yes	YES enforcement gap	Every /admin/* route called by the FE, including: GET /admin/dashboard GET /admin/customers GET /admin/officers GET /admin/audit/tickets GET /admin/product-flyers PATCH /admin/customers/{id}/reassign	The web app has NO middleware.ts and ProtectedRoute checks authentication only, never role - so an OFFICER can type /admin/officers into the address bar and the page renders. The sidebar merely hides the links. Client-side gating is being added, but the server must be the authority: /admin/* must 403 for non-ADMIN, /regional/* for non-REGIONAL_ADMIN, /loading/* for non-LOADING_OFFICER, and /officers/* must stay scoped to the caller's own customers. Confirm the JWT carries a role claim validated on every request.	n/a - enforce on all existing routes	n/a	n/a. Role claim required in the JWT.	403 for a role mismatch (the FE already renders a message: "You do not have permission to perform this action.", "statusCode": 403)
CC-02 Secure auth token storage	Web	Pending	5 days	Yes	YES modify	POST /auth/staff/login POST /auth/staff/web-login POST /auth/refresh POST /auth/logout	Tokens are returned in the JSON body and stored with js-cookie, which cannot set httpOnly. Both the access and refresh token are therefore readable by any XSS on the page. It also blocks CC-01: Next.js middleware cannot read a JS-set cookie reliably, so server-side route gating is impossible until this changes. Preferred fix: set the tokens as httpOnly + Secure + SameSite=Lax cookies on login and refresh, clear them on logout, with CORS credentials enabled for the web origin.	n/a - change token delivery on existing routes	Unchanged	n/a. Requires CORS Access-Control-Allow-Credentials: true and an explicit origin.	Response headers: Set-Cookie: access_token=eyJ...; HttpOnly; Secure; SameSite=Lax; Path=/; Max-Age=3600 Set-Cookie: refresh_token=eyJ...; HttpOnly; Secure; SameSite=Lax; Path=/auth; Max-Age=2592000 Body (tokens no longer included): { "user": { "id": "stf_5", "name": "Chidi Eze", "role": "REGIONAL_ADMIN", "region": "EASTERN" } }
CC-05 Contact-us form submission	Web	Pending	3 days	Yes	NO new	None - components/contact/ContactForm.tsx validates and resets but posts nowhere. It exposes an onSubmit hook ready to wire.	Public marketing form on /contact-us. The FE already validates fullName (min 2 chars), email format, phone (7-20 chars, digits and + - () only) and message (min 10 chars), and surfaces the API 'message' on failure. Unauthenticated public route, so it should be rate-limited or captcha-guarded to avoid being used as a spam relay.	POST /contact	{ "fullName": "Ada Obi", "email": "ada@example.com", "phone": "+2348012345678", "message": "I would like to discuss a distributorship." }	n/a. No auth. Rate limit by IP.	201: { "message": "Thanks for reaching out. We'll get back to you within 24 hours." } 429: { "message": "Too many requests. Please try again later.", "statusCode": 429 }
BE-01 Registration & OTP edge cases: expiry, resend, lockout	Mobile	Pending	5 days	No	YES modify	POST /auth/customer/request-otp POST /auth/customer/verify-otp Both are used twice: first-time registration and the forgot-password reset flow, so verify-otp must serve as both 'activate account' and 'reset password'.	The backend returns only a free-text message, so the app cannot show the 10-minute expiry, a working resend, or the 30-minute lockout after 3 wrong attempts. ADD to request-otp: expiresAt, expiresInSeconds, resendAvailableAt, resendAfterSeconds. ADD a stable machine-readable 'code' on every error. ADD attemptsRemaining on OTP_INVALID, and lockedUntil + retryAfterSeconds on OTP_LOCKED. Calling request-otp again must invalidate the previous code and apply the cooldown. GUARD: never return devOtp/devNote outside dev. MUST NOT change the verify-otp success keys access_token, refresh_token, user.id/name/role.	n/a - extend both existing endpoints	Unchanged. Optional additive field: { "phone": "+2348012345678", "purpose": "REGISTRATION" } "PASSWORD_RESET" If added it must stay optional - the shipped build does not send it.	None. code enum: OTP_EXPIRED OTP_INVALID OTP_LOCKED OTP_RESEND_TOO_SOON PHONE_NOT_FOUND	200 request-otp: { "message": "OTP sent", "expiresAt": "...", "expiresInSeconds": 600, "resendAvailableAt": "...", "resendAfterSeconds": 60 } 400 {"code": "OTP_INVALID", "message": "The code you entered is incorrect.", "attemptsRemaining": 2} 410 {"code": "OTP_EXPIRED", "message": "This code has expired."} 423 {"code": "OTP_LOCKED", "message": "Too many incorrect attempts.", "lockedUntil": "...", "retryAfterSeconds": 1800} 429 {"code": "OTP_RESEND_TOO_SOON", "retryAfterSeconds": 37}
BE-02 Bottom-navigation badge counts	Mobile	Pending	5 days	No	NO new	None from the bottom navigation. Related lists: GET /notifications/me (already returns unread) GET /customers/me/purchases GET /customers/me/invoices GET /customers/me/waybills GET /chat/me GET /tickets/customer	The six tabs exist in BottomNavWidget but there is no data source for the counts. Deriving them from the five list endpoints would mean five requests on every app foreground. Provide one cheap aggregate. Counts: payment, invoice, waybill (changed since the tab was last opened), chat (STAFF messages with readAt null), support (unread STAFF ticket replies), notifications (mirrors the existing unread). Because 'last opened' is server state, a companion mark-as-seen route is required. Chat and support are already derivable from readAt, so they can ship first if tab-seen tracking is deferred.	GET /customers/me/mobile-badges PATCH /customers/me/mobile-badges/seen Auth: bearer, role CUSTOMER. Customer resolved from the token - no id in the path.	GET: none. PATCH: { "tabs": { "chat", "waybill" } } any subset of payment invoice waybill chat support notifications; unknown value -> 400; must be idempotent.	GET: optional tabs=chat,support (comma-separated). Omitted -> all counts. Counts-only query, must respond well under 300 ms - called on every app foreground.	200: { "counts": { "payment": 2, "invoice": 0, "waybill": 1, "chat": 4, "support": 1, "notifications": 6 }, "totalUnread": 14, "generatedAt": "..."} All counts must be non-negative integers and present even when 0 - a missing key is treated as an error.
BE-03 Home screen must supply 5 recent purchases	Mobile	Pending	3 days	No	YES modify	GET /customers/me/home	The PRD requires the home screen to show the last 5 orders; the app renders 3. Trimming is a mobile change, but the app can only display 5 if the backend returns 5 - the size of recentPurchases is entirely backend-controlled and currently unspecified. Return the 5 most recent ordered by orderDate descending. Also return productFlyers: [] - an empty array, never null and never a placeholder flyer - so the app can hide the flyer section as the PRD requires. Keep every existing key name.	n/a - extend existing route	None - GET request.	None currently sent. Optional additive: recentLimit (integer 1-10, default 5).	{ "customerName": "Ada Obi", "accountBalance": { "amount": 1250000.00, "lastUpdated": "...", "isLow": false }, "stockBalance": { "totalCartons": 1200, "loadedCartons": 800, "remainingCartons": 400 }, "productFlyers": [], "recentPurchases": { "id": "pur_01", "erpId": "SO-10231", "orderDate": "...", "totalItems": 12, "totalValue": 480000, "status": "COMPLETED", ... 5 items } }
BE-04 Linked invoice number on order / payment detail	Mobile	Pending	5 days	No	YES modify	GET /customers/me/purchases?page&pageSize (powers both the Payment list and the Payment Detail screen - detail renders from the list item, there is no per-purchase endpoint) GET /customers/me/invoices GET /customers/me/invoices/{invoiceId}	The purchase payload contains no invoice reference of any kind, so the app has nothing to display and no id with which to open the invoice. ADD to every element of data[]: invoiceId (the id accepted by /invoices/{invoiceId}), invoiceNumber (human-readable), and optional invoiceStatus mirroring the invoice list. Both must be nullable and always present rather than omitted. If one order can map to MORE than one invoice, replace them with invoices:[{id,invoiceNumber,status}] and tell the mobile team first - it changes the detail layout. Nothing may be removed; erpId is the order reference throughout the Payment screens.	n/a - extend existing route. A dedicated /purchases/{id} is NOT required.	None - GET request.	Currently: page, pageSize. Requested additions (the app filters client-side over one page of 20, which silently hides older orders): startDate, endDate (YYYY-MM-DD on orderDate) status: PROCESSING COMPLETED CANCELLED search: over erpId and items[].productName All optional and combinable; meta must reflect filtered totals.	{ "data": [{"id": "pur_01", "erpId": "SO-10231", "orderDate": "...", "totalItems": 12, "totalValue": 480000, "status": "COMPLETED", "invoiceId": "inv_01", "invoiceNumber": "INV-2026-0453", "invoiceStatus": "UNPAID", "items": [{"id": "itm_1", "orderDate": "2026-04-01", "productName": "Vijju Milk 15cl x24", "quantity": 8, "unitPrice": 40000, "lineTotal": 320000}]}], "meta": {"total": 37, "page": 1, "pageSize": 20, "totalPages": 2}}
BE-05 Waybill detail view	Mobile	Pending	5 days	No	PARTIAL list exists, no detail	GET /customers/me/waybills?page&pageSize POST /customers/me/waybills (submit loading request) POST /customers/me/waybills/accept-terms	The list response contains none of the officer, timeline or document fields, so a detail screen cannot be built from it. The POST loading-request response already returns assignedOfficerId, assignedAt, loadingStartedAt, completedAt, waybillDocumentUrl, notes, termsAcceptedAt, externalFormUrl and region - THESE EXIST SERVER-SIDE BUT ARE NEVER EXPOSED ON READ. (a) Add a detail endpoint returning the full record with the officer RESOLVED to name and phone (the app has no staff-directory endpoint). (b) Add assignedOfficer(id,name) and hasDocument to each list row. waybillDocumentUrl must be openable by the app - a pre-signed URL with a stated TTL, or one that accepts the bearer header. Return 404 not 403 for another customer's waybill so ids cannot be enumerated.	GET /customers/me/waybills/{waybillId} Auth: bearer, role CUSTOMER.	None - GET request.	Detail: none. List currently page / pageSize. Requested: startDate, endDate (YYYY-MM-DD on requestedLoadingDate) and status. CONFIRM the authoritative status enum - the app colours statuses by string matching: PENDING APPROVED LOADING COMPLETED REJECTED. Enriched list row adds: "assignedOfficer": { "id", "name", "hasDocument": true 404 {"code": "WAYBILL_NOT_FOUND", "message": "Waybill not found." }	

Issue	Platform	Status	Time Line	Endpoint Provided	Endpoint Exists?	Existing Frontend / Mobile Endpoint(s)	Expectation / Required Backend Changes	New Endpoint (if Required)	Request Body	Query / Filters	Sample Response
BE-06 External T&C / loading form URL	Mobile	Pending	3 days	No	YES modify (decision needed)	POST /customers/me/waybills/accept-terms POST /customers/me/waybills	formUrl is already modelled but is empty in practice, so the app ignores it and opens its own LoadingFormDialog. DECISION REQUIRED. Option A (recommended, already working): keep the in-app form, return formUrl: null and a real terms version - the mobile team then needs written sign-off that the PRD's 'external form URL' wording is satisfied. Option B: return a resolvable formUrl the app opens in a webview - it must (i) identify the customer via a signed, single-use, short-lived token IN THE URL because the webview will not carry the bearer token, (ii) state an expiry, and (iii) declare a success redirect the app can intercept, otherwise the app can never know the request was submitted. Independently: replace the literal 'agreed' with a versioned identifier, and expose termsAcceptedAt + currentTermsVersion on GET /customers/me so a returning customer is not asked again.	n/a - both options are satisfied by the existing accept-terms route plus two additive profile fields.	{"termsVersion":"v1.2"} Current build hardcodes "agreed". Reject unknown/outdated versions with 400 TERMS_VERSION_INVALID. Accepting the same version twice must be idempotent, returning the original acceptedAt.	None.	Option A: { "formUrl":null, "acceptedAt":"...", "termsVersion":"v1.2", "note":"Terms accepted." } Option B: { "formUrl":"https://forms.viju.ng/loading?t=...", "formUrlExpiresAt":"...", "successRedirectUrl":"vijuapp://loading-request/success", "acceptedAt":"...", "termsVersion":"v1.2" } 400 {"code":"TERMS_VERSION_INVALID", "currentTermsVersion":"v1.3"}
BE-07 Push notifications	Mobile	Pending	5 days	No	NO new	GET /notifications/me?page&pageSize PATCH /notifications/me/read-all PATCH /notifications/{notificationId}/read (in-app only - these work solely while the app is open)	No device-token registration endpoint and no push integration exist anywhere. Register/refresh a token after login, deregister on logout. Deliver via Firebase Cloud Messaging (FCM covers Android and iOS via APNs) on: waybill status change, staff chat message, staff ticket reply, and optionally invoice issued / overdue. Every push must carry a data payload with type, entityId and notificationId so the app can deep-link, and must ALSO create the matching in-app record so the two lists never diverge. Deduplicate - one event, one push per device. SAME DELIVERY WORK AS WEB AD-13. INPRA PREREQUISITE before mobile work can start: Firebase project, google-services.json, GoogleService-Info.plist, APNs auth key uploaded, FCM server key held backend-side, bundle ids matching the shipped app.	POST /customers/me/devices (upsert on token) DELETE /customers/me/devices/{token} A body-based POST /devices/unregister is acceptable if path-encoding the token is awkward. A token registered by one customer must be REASSIGNED, not duplicated, when another logs in on the same device.	{"token":"fMEp0vJ...:APA91BH...", "platform":"android", "deviceId":"...", "appVersion":"1.0.3+4", "osVersion":"Android 15"} token and platform required (android ios); the rest optional. DELETE takes no body.	None. Stale tokens rejected by FCM must be purged server-side.	201: { "id":"dev_01", "token":"fMEp0vJ...", "platform":"android", "customerId":"cus_01", "createdAt":"...", "updatedAt":"...", "status":"active" } 204 on deregistration (app accepts 200 and 204 alike). FCM payload: { "notification":{ "title":"Waybill WB-2026-0091 updated", "body":"Your loading request is now LOADING.", "data":{ "type":"WAYBILL_STATUS", "entityId":"wb_01", "notificationId":"ntf_01", "deepLink":"vijuapp://waybill/wb_01" } } } type enum must match /notifications/me - PLEASE PUBLISH IT.
BE-08 Realtime chat (officer replies without manual refresh)	Mobile	Pending	5 days	No	PARTIAL no cursor, no receipts	GET /chat/me - returns a BARE JSON ARRAY, not an object POST /chat/me	ChatScreen fetches the whole thread once in initState and afterwards only appends messages the customer sends. No polling, no websocket, no cursor - re-fetching means re-downloading the entire conversation. WARNING: the app throws 'Invalid chat response' if the body is not an array, so this must NOT be wrapped in a data envelope without a coordinated mobile release. ADD ?since= returning only messages strictly newer, with guaranteed ascending createdAt and a strictly monotonic per-message timestamp (or expose a monotonic seq integer) so no message can be skipped. ADD ?limit (default 50, max 200) and ?before for scroll-back. ADD read receipts - readAt is already in the model but nothing can write it, which also blocks the chat badge in BE-02. senderLabel should read 'Viju Account Officer' for all STAFF messages.	No for the incremental fetch - extend GET /chat/me with query params. YES, one small route: PATCH /chat/me/read Optional: wss://<host>/ws/chat (polling stays the fallback)	POST unchanged: { "content":"...", "attachmentUrl":"..." } - the app always sends attachmentUrl and uses "" when there is no image, so treat "" as no attachment. PATCH /chat/me/read: { "upTo":"2026-08-19T15:40:12.000Z", "preferred":true, "messageIds":["msg_01","msg_02"] } Must be idempotent.	On GET /chat/me - all optional, all additive: since (ISO-8601, strictly newer) before (ISO-8601, scroll-back) limit (default 50, max 200) With no parameters the endpoint must behave EXACTLY as it does today so the shipped build keeps working.	200 - array, never an object: [[{ "id":"msg_01", "content":"Your loading request has been approved.", "senderType":"STAFF", "senderLabel":"Viju Account Officer", "createdAt":"...", "readAt":null }]] An empty poll returns [] with status 200 - never 204, never null. 200 PATCH /chat/me/read: { "updated":3, "unread":0 }
BE-09 Chat image upload: folder value and 5 MB validation	Mobile	Pending	3 days	No	YES modify	POST /uploads?folder=profile-photos - multipart, called from ChatRemoteDataSourceImpl POST /chat/me - the returned url is sent as attachmentUrl	EVERY chat and ticket attachment is currently stored in the profile-photos folder, because that is the only folder value the app knows - this needs a data migration the longer it runs. Accept folder=chat-attachments, publish the full list of accepted folder values, and reject unknown ones with 400 instead of silently defaulting. Enforce the PRD's 5 MB limit SERVER-SIDE and return a structured error including maxBytes. Enforce an allow-list of the six image MIME types the app can send. CONFIRM whether HEIC/HEIF are storable and servable - iOS produces them by default and mobile must convert if not. MUST NOT change the field name 'file' of the response keys url, key, size, mimeType. The returned url must be readable by the message recipient - the app renders it in Image.network with no custom headers.	n/a - extend the existing upload route.	multipart/form-data: file = <binary> (field name is exactly "file") folder = "chat-attachments" (also sent as a form field) Validation: file required; size <= 5 242 880 bytes; MIME in the allow-list; folder in the published enum.	folder - required, currently sent as BOTH a query parameter and a form field. Requested accepted values: profile-photos chat-attachments ticket-attachments	200 (shape unchanged): { "url":"https://cdn.viju.ng/chat-attachments/2026/08/19/8f2c1a.jpg", "key":"chat-attachments...", "size":842104, "mimeType":"image/jpeg" } 413 {"code":"FILE_TOO_LARGE", "message":"Image must be 5MB or smaller.", "maxBytes":5242880, "receivedBytes":8310442} 415 {"code":"UNSUPPORTED_MEDIA_TYPE", "allowed":["image/jpeg", "image/png", "image/webp", "image/gif", "image/heic", "image/heif"]} 400 {"code":"VALIDATION_ERROR", "message":"Unknown folder.", "allowed":["profile-photos", "chat-attachments", "ticket-attachments"]}
BE-10 Support ticket image upload: folder value and validation	Mobile	Pending	3 days	No	YES modify	POST /uploads?folder=profile-photos - shared helper for ticket creation and replies POST /tickets POST /tickets/{ticketId}/replies GET /tickets/customer?page&pageSize GET /tickets/{ticketId}	Same two defects as BE-09: wrong folder, and no size or type validation. Accept folder=ticket-attachments with the identical validation contract. PUBLISH the authoritative category enum - the app currently sends the display strings 'Account Query', 'Delivery Issue', 'Product Query', 'Other'; if the backend expects codes such as ACCOUNT_QUERY, say so and the app will send codes and render labels locally. Silent acceptance of arbitrary strings is today's behaviour and makes reporting unreliable. PUBLISH the ticket status enum too. Treat an empty-string attachmentUrl as null so threads do not contain empty URLs the app tries to render. ADD unreadReplies and lastReplyAt to ticket list rows - needed for the BE-02 support badge and to avoid opening every thread.	n/a - extend existing routes.	Upload identical to BE-09 with folder=ticket-attachments. Ticket create/reply bodies unchanged. Validation on create: category in the published enum; subject 1-120 chars; description 1-2000 chars; attachmentUrl optional and must be a URL the backend itself issued.	Upload: folder=ticket-attachments. Requested optional additions: status and category filters, so the list is filtered server-side rather than within a single 20-row page.	200 enriched ticket row: { "data":{ "id":"tkt_01", "ticketId":"TKT-2026-0188", "category":"DELIVERY_ISSUE", "subject":"Truck not loaded", "attachmentUrl":null, "status":"OPEN", "unreadReplies":2, "lastReplyAt":"...", "createdAt":"...", "meta":{ "total":4, "page":1, "pageSize":20 } } } 400 {"code":"VALIDATION_ERROR", "message":"Unknown category.", "allowed":["ACCOUNT_QUERY", "DELIVERY_ISSUE", "PRODUCT_QUERY", "OTHER"]}
BE-11 Support thread sender label	Mobile	Pending	3 days	No	YES modify	GET /tickets/{ticketId} - the full thread POST /tickets/{ticketId}/replies	Replies carry senderType and a raw staffId but no display name, and the app has NO endpoint with which to resolve a staff id to a person - so staff replies cannot be labelled at all. ADD senderLabel to every element of replies[]: for senderType STAFF return 'Viju Support' (or 'Viju Account Officer' - CONFIRM the preferred wording and keep it consistent with the chat label in BE-08); for CUSTOMER return the customer's name. Return the same senderLabel on the POST reply response so an optimistically-rendered reply matches a later refresh. CONFIRM the authoritative senderType values - the app compares against 'STAFF' and 'CUSTOMER', and any other casing silently renders every message on the wrong side of the thread. Nothing should be removed; staffId can stay for audit.	n/a - one additive field on existing responses.	GET thread: none. POST reply unchanged: { "content":"...", "attachmentUrl":"..." }	None. If threads can grow long, optional limit / before paging on replies[] would help - not required for launch.	200 GET /tickets/{ticketId}: { "id":"tkt_01", "ticketId":"TKT-2026-0188", "status":"IN_PROGRESS", "customer":{ "...", "replies":[{ "id":"rep_01", "senderType":"CUSTOMER", "staffId":null, "senderLabel":"Ada Obi", "content":"Any update on this?", "createdAt":"...", "id":"rep_02", "senderType":"STAFF", "staffId":"stf_01", "senderLabel":"Viju Support", "content":"We have escalated this to the depot.", "createdAt":"..." }] } }
BE-12 Profile account number	Mobile	Pending	3 days	No	CLARIFY then modify	GET /customers/me PATCH /customers/me/photo PATCH /customers/me/password	The PRD lists 'account number' as a profile field; the app has only erpId, rendered as 'Account <erpId>'. DECISION REQUIRED - is erpId the number the customer sees on their invoices and quotes? If YES, no backend change and the mobile team relabels the field. If NO, add a nullable accountNumber string; the app will prefer it and fall back to erpId, so the change is safe to deploy in either order. INDEPENDENTLY: settle accountOfficer on ONE shape and keep it - the app defensively handles a plain string, an object with displayName, an object with name, and null. Adding the officer's phone would let the profile offer a direct call action. Also add termsAcceptedAt and currentTermsVersion here (see BE-06).	n/a - additive fields on the existing profile route.	None - GET request.	None.	200 GET /customers/me (additions marked): { "id":"cus_01", "erpId":"CUS-4471", "accountNumber":"VJ-0044710", "name":"Ada Obi", "phone":"+23480012345678", "region":"EASTERN", "accountStatus":"ACTIVE", "outstandingBalance":1250000, "accountOfficer":{ "id":"stf_01", "name":"Chidi Umeh", "phone":"+2348140000000", "termsAcceptedAt":"...", "currentTermsVersion":"v1.2" } }